Situation description:
You are a cybersecurity specialist at company **XYZ**, operating in a critically important sector subject to the **National Cybersecurity Law** and **minimum cybersecurity requirements**. Company management expects you to develop and implement a security strategy ensuring compliance with these regulations and strengthening the organisation's resilience against cyber threats.

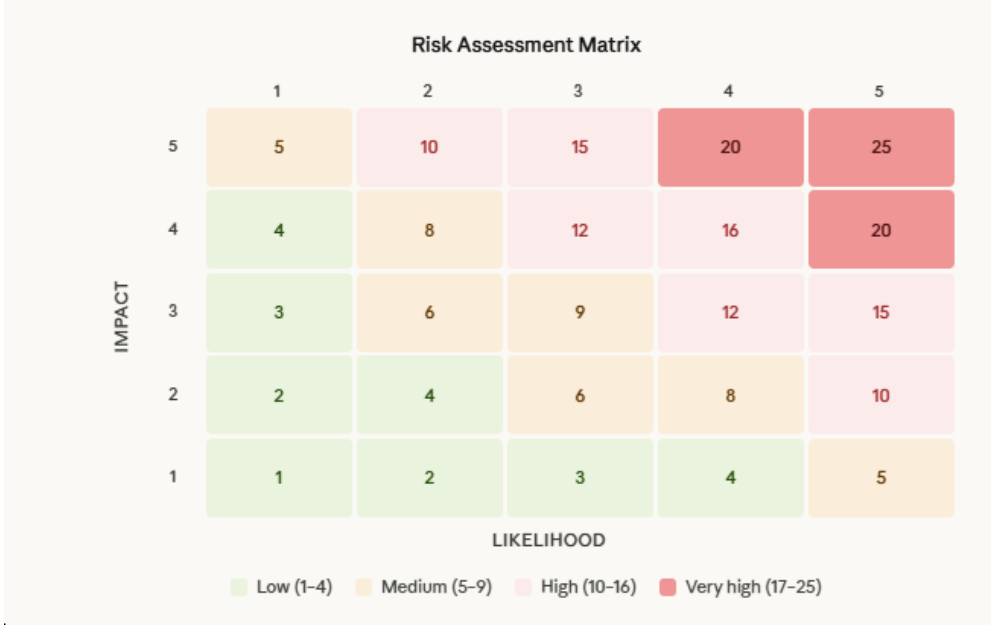
As part of the compliance process, you have begun working on an **information systems (IS) catalogue** and **ICT resource catalogue**. These catalogues are essential for identifying and classifying all company information assets and technology resources, and ensuring their security management.

One of the company's key systems – the ABS system – is hosted on a **local server** within the company's internal network. The system uses **cloud-based data backup** to ensure information availability and recovery options in the event of a critical incident.

In the initial assessment, the ABS system was assigned **Security Class C** in accordance with minimum cybersecurity requirements.

You are required to perform a **risk analysis of the ABS system**, taking into account the **minimum cybersecurity requirements** and the **National Cybersecurity Law**.

Risk assessment matrix ==>>:



Task 1 (25% of grade) – Defence-in-Depth
Defence-in-Depth is a security concept where data is placed at the centre and surrounded by protective layers using various security controls. Identify at least two control mechanisms for each layer.

Software & Applications Layer	**Endpoint & Server Security Layer**	**Network Security Layer**	**Physical Security Layer**	**Organisational Layer**
Security updates and patch management	Antivirus and EDR (Endpoint Detection and Response) solutions	Firewall and IDS/IPS systems (Intrusion Detection /Prevention)	Access control systems (e.g. card or biometric authentication)	Cybersecurity policy and procedures
Application whitelisting – only approved and verified software is permitted to run on company systems.	Restricted administrator access and activity log monitoring	Network segmentation and VLAN isolation – separating critical systems into isolated network zones to limit lateral movement	Video surveillance and restricted server room access	Employee training and awareness programmes, supported by an Incident Response Plan defining clear procedures in the event of a security incident

Task 2 (25% of grade) – Risk Analysis

1. Identify at least five potential risks that could threaten the company's operations.
2. Calculate the impact and likelihood of each risk.
3. Assess the residual risk.

   Note: Control measures must not be taken from Task 1.

Risk	**Impact Description**	**Likelihood (1-5)**	**Impact (1-5)**	**Risk Level**	**Control Measures**	**Control Effectiveness (0-1)**	**Residual Risk**
Critical system attack (DDoS, ransomware, etc.)	ABS system is paralysed, company operations halt	4	5	20 (very high)	Data backup and recovery plan, network protection against DDoS, offline backup copies to prevent ransomware from encrypting backups.	0,7	6 (medium)
Internal Access compromise	Unauthorized access to ABS system, data breach or manipulation	3	3	9 (medium)	Strict access control (RBAC) activity monitoring, MFA	0,8	1,8 (low)
Data loss or corruption	Deletion or corruption of critical data affecting company operations	3	4	12 (medium)	Automated backup strategy with regular recovery testing and verification of backup integrity	0.9	1,2 (low)
Human error	Incorrect data	4	3	12 (medium)	Dual control	0,7	3,6 (low)

	entry process causing system instability or data loss				principle – critical actions require approval from two authorised persons; activity audit logs		
Physical infrastructure failure	Server failure, power outage, data centre damage	2	3	6 (low)	Redundant data centre, UPS systems, backup power sources	0,9	0,6 (low)

Task 3 (25% of grade) – Risk Mitigation Controls

1. Select two potential cybersecurity risks that could threaten the ABS system. Risk may be selected from Task 2.
2. For each risk, propose one control mechanism that would help mitigate it.
3. Briefly explain how these mechanisms help protect the system.

Risk	Control Mechanism	Explanation
Critical system attack (DDoS, ransomware, etc.)	Network protection using Web Application Firewall (WAF) and Traffic filtering	A WAF and traffic filtering solution helps block malicious requests before they reach the server, reducing the load on system resources and preventing service disruption. Suspicious traffic patterns – such as abnormally high request volumes typical of DDoS attacks – are automatically identified and blocked, ensuring system availability even during an active attack.
Internal access compromise	Multi-Factor Authentication (MFA) combined with Role-Based Access control (RBAC)	MFA requires users to provide an additional authentication factor (such as a code from a mobile application), significantly reducing the risk of unauthorised access even if credentials are compromised. RBAC ensures that users are granted only the minimum permissions necessary for their role – for example, a finance employee has access only to financial data, not to ABS system configuration settings. This limits the potential damage caused by both malicious insiders and accidental misuse.

Task 4 (25% of grade) – Incident Response: Ransomware Attack
One morning, the company's IT department discovers that several employees' computers have been encrypted and a ransom demand appears on screen requesting payment for data recovery. System logs indicate a possible ransomware attack, likely spread through a phishing email.

1. Describe the steps you would take in the first hours after the incident is discovered.
2. Identify at least three preventive measures the company can implement to prevent such an incident from recurring

1. **Response steps:**

Step	Description
1	**Evidence preservation** – before isolating affected systems, capture memory dumps and screenshots of the ransom note to support forensic investigation. Document the time of discovery and initial indicators.
2	**Incident isolation** – immediately disconnect infected computers from the network (both physically and logically) and block access to prevent further spread. Disconnect any connected storage devices.
3	**Notification** – inform company management and the legal department. If personal data may have been compromised, notify the data protection authority within 72 hours as required by GDPR. Contact CERT.LV for technical assistance and guidance.
4	**Investigation and analysis** – review system logs to determine the infection source (e.g. the phishing email), identify all affected devices and assess the full extent of the damage. Engage cybersecurity specialists if needed.
5	**Data recovery** – restore systems and files from clean, verified backups. Confirm that backups are not infected before use. Conduct additional analysis to ensure all threats have been fully eradicated before bringing systems back online.
6	**Credential reset** – reset all user and service account passwords company-wide immediately after systems are restored. This prevents attackers who may have harvested credentials during the breach from regaining access using previously stolen login details.

2. **Preventive Measures:**

Measure	Description
1	**Employee training and awareness** – conduct regular training on recognising phishing emails, suspicious links and attachments. Simulate phishing attacks to test and reinforce employee awareness.
2	**Email security hardening** – implement robust email filtering with SPF, DKIM and DMARC to block malicious messages. Configure email security solutions to automatically identify and quarantine suspicious attachments and

	links.
3	**Software updates and endpoint protection** – regularly update operating systems and software to eliminate known vulnerabilities. Deploy EDR (Endpoint Detection and Response) solutions to detect and block suspicious behaviour in real time.
4	**Regular data backup and recovery testing** – ensure automated and regular backups (both local and cloud-based), including offline copies that ransomware cannot encrypt. Regularly test the recovery process to verify its effectiveness and reliability.
5	**No ransom payment policy** – establish a formal organisational policy never to pay a ransom, as payment does not guarantee data recovery and directly incentivises further attacks. Instead, invest in reliable, regularly tested offline backups that eliminate any need to consider payment and ensure fast, independent recovery.